

REGIONALNI CENTAR ZA PREDINKUBACIJU U PAMETNOJ INDUSTRIJI



Sufinancira
Europska unija



Projekt je financiran putem ITU
mehanizma u okviru ITP-a



CYBER ATTACKS – SOME EXAMPLES

1



HAKIRANE LOKALNE VLASTI

Dio Londona pogođen kibernetičkim napadom, građanima stiglo upozorenje: 'Podaci su kopirani i ukradeni'

Stručnjak za kibernetičku sigurnost Graeme Stewart rekao je da su lokalne vlasti meta jer "imaju puno stvarno zanimljivih podataka"

3

Kibernetički napad usporava zračni promet u Europi

Nenad Kreizer dpa, Reuters
20.09.2025

Kibernetički napad nepoznatog porijekla na sustave ukrcavanja u zračnim lukama izaziva kašnjenja u zračnom prometu diljem Europe. Pogođeni su i letovi Croatia Airlinesa.



SICK

WWW.SICK.COM

2

Kibernetički napad na Istarsku županiju: Pala mreža, servisi u potpunom prekidu!

Istarska županija noćas je postala meta ozbiljnog kibernetičkog napada koji je privremeno srušio ključne digitalne sustave i onemogućio pristup službenoj stranici, e-pošti i online servisima.



Igor Franković 1 Prosinac 2025 | 11:44



4

Krim-policija u Lencu. Tvrtka kazneno prijavila nepoznatog počinitelja, šteta je višemilijunska

Orjana Antešić
26. ožujak 2026 10:20



CLOUD & CYBERSECURITY IN INDUSTRIAL SYSTEMS

Siniša Husnjak

CloudSecOps Project manager

SICK Mobilisis <> FOI

Varaždin, 28.4.2026.



AGENDA

1) Cyber Attacks

- why it matters!

2) IIoT platform

- Security by design

3) IIoT Cybersecurity elements

- Full view

4) Regulatory and compliance

- NIS2, CRA, RED

5) Conclusion and remarks



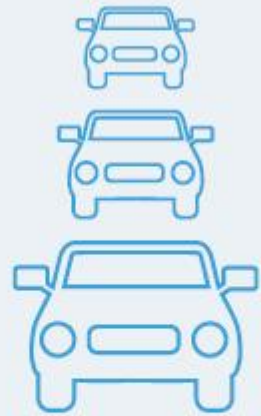
FROM INDUSTRY 1.0 TO 5.0

→Missing human aspect

→Industry 5.0



Merchanization,
water and steam
powered



Mass production
assembly line,
electricity



Robotics,
automation
computers



Networked
communication data
sourcing



“STARTUP IOT SOLUTION FOR MANUFACTURING”

→ what can go wrong?”

Scenario:

- IoT devices are deployed with **default** passwords
- An attacker **scans** the network and discovers the devices
- The attacker **gains access** to the device
- Pivot into the cloud via APIs or exposed credentials
- **Manipulation** of data or system shutdown follows

✦ Result:

- ✗ production halts/stops
- ✗ inaccurate data → wrong decisions
- ✗ potential damage to manufacturing equipment
- ✗ reputational damage + financial losses

“Cyber attacks don’t stop at IT — they stop production.”

CYBER ATTACKS IN INDUSTRY - STUXNET

“Like a movie scenario”

Stuxnet – MITRE-aligned Weapon Behavior

- Gained **initial access** via removable media and Windows zero-day exploits
- Performed controlled **lateral movement** across Windows engineering networks
- Executed with high trust using **stolen** code-signing certificates
- Deployed **malicious** PLC logic through Siemens Step7 engineering software
- **Evaded detection** using Windows + PLC rootkits and falsified process telemetry
- Achieved **cyber-physical impact** by degrading uranium enrichment centrifuges

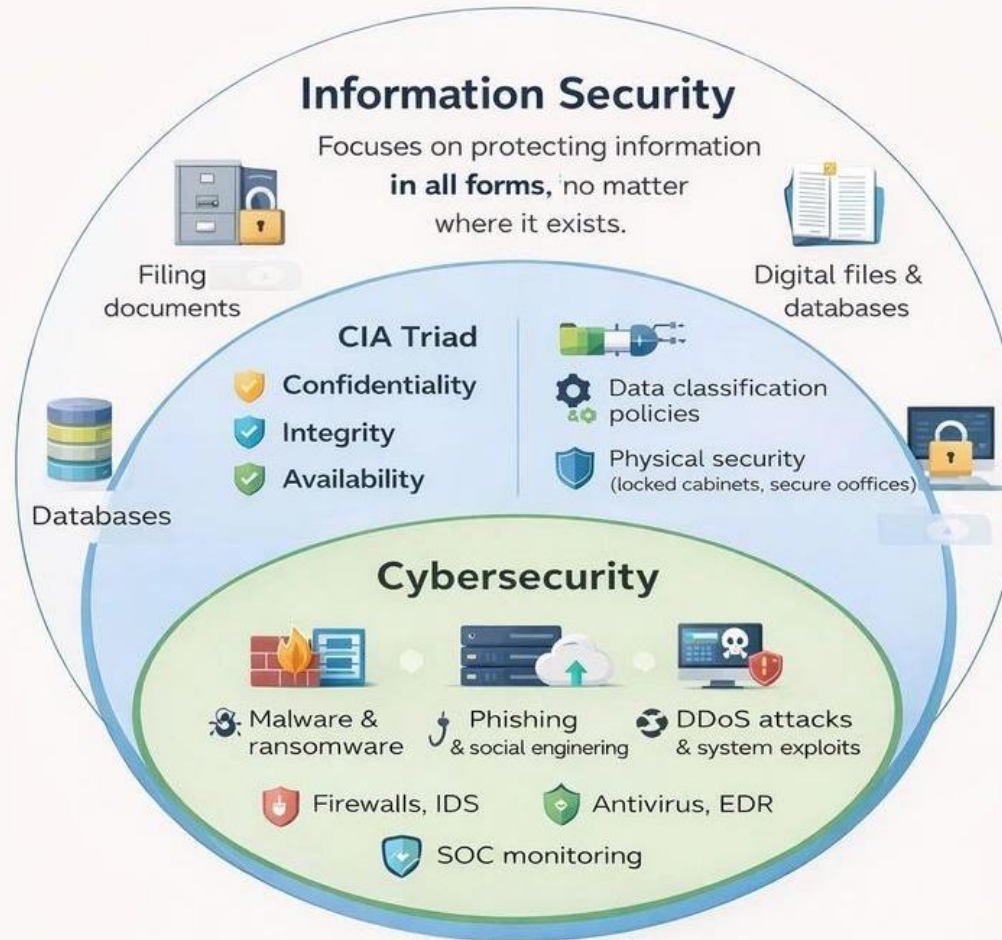
MITRE ICS Chain (simplified):

Initial Access → Lateral Movement → Execution → Defense Evasion → Persistence → Impact



Cybersecurity vs Information Security

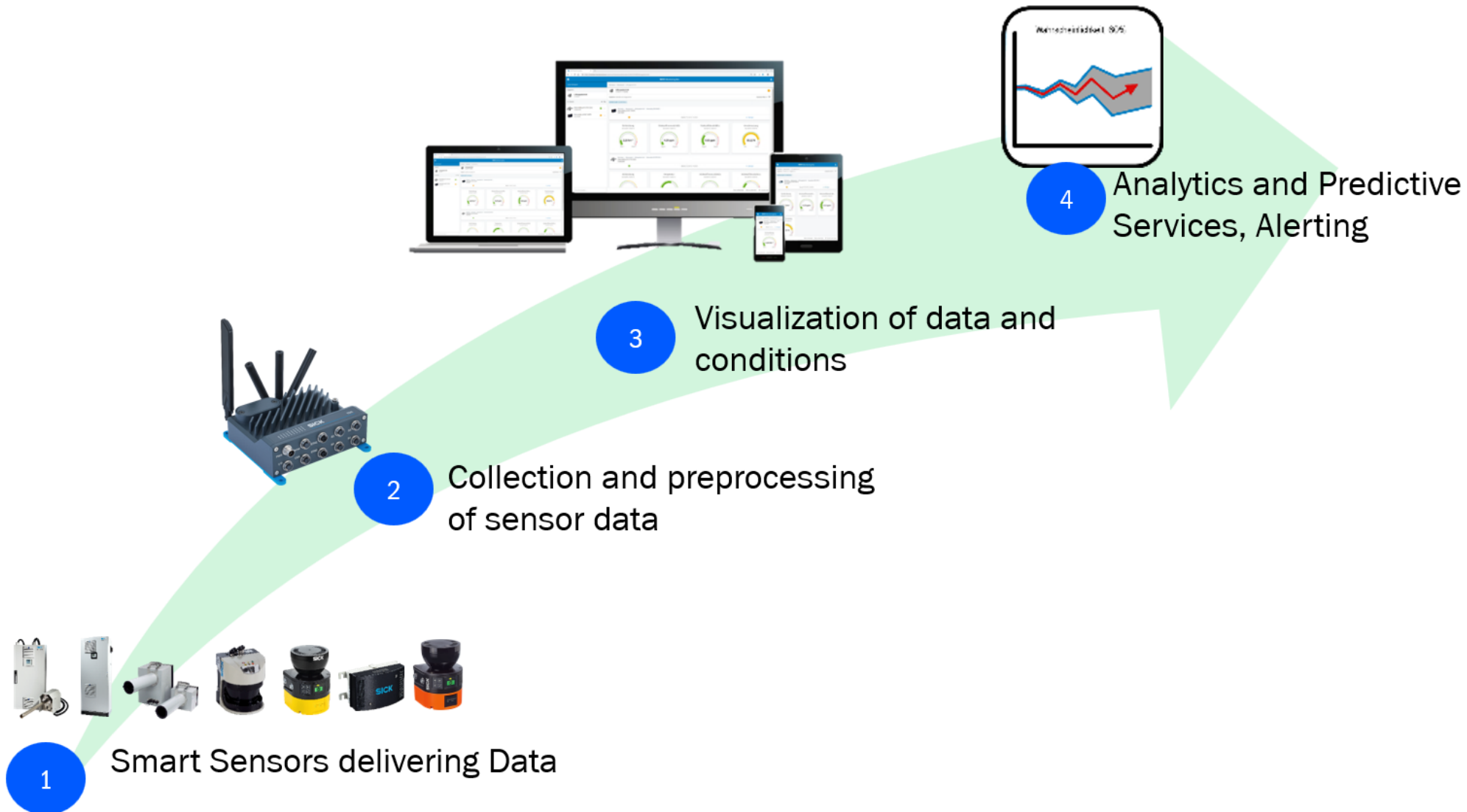
Same Goal, Different Scope



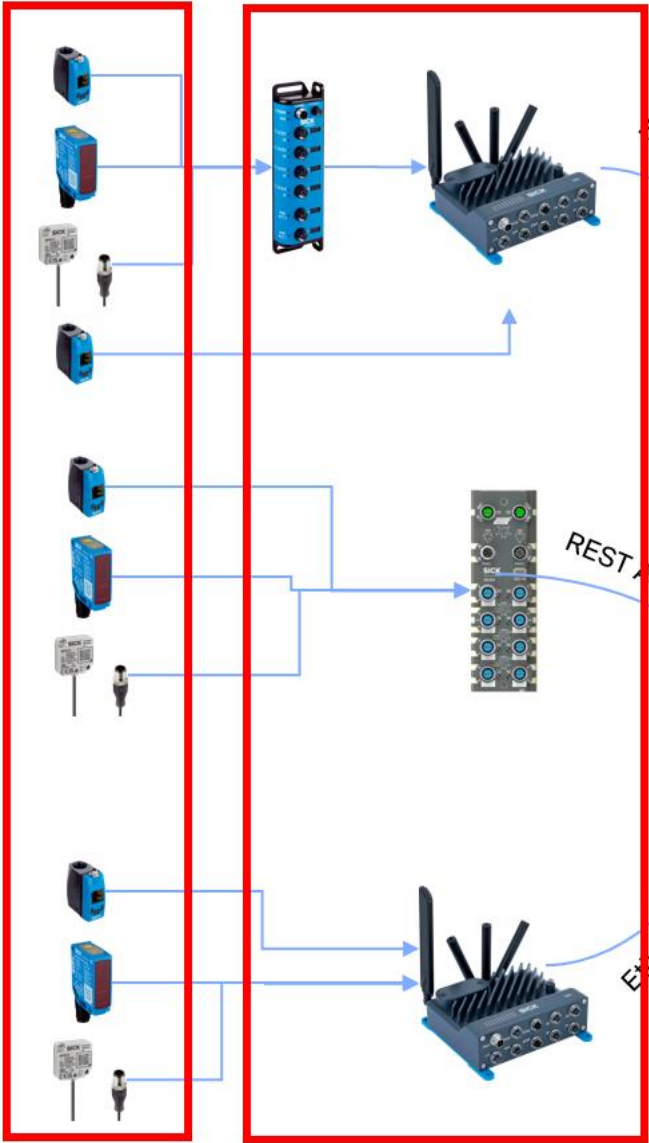
All Cybersecurity is Information Security, but not all Information Security is Cybersecurity.

Firewalls, IDS Antivirus, EDR SOC monitoring

SENSOR > DIGITAL SERVICE > PEOPLE



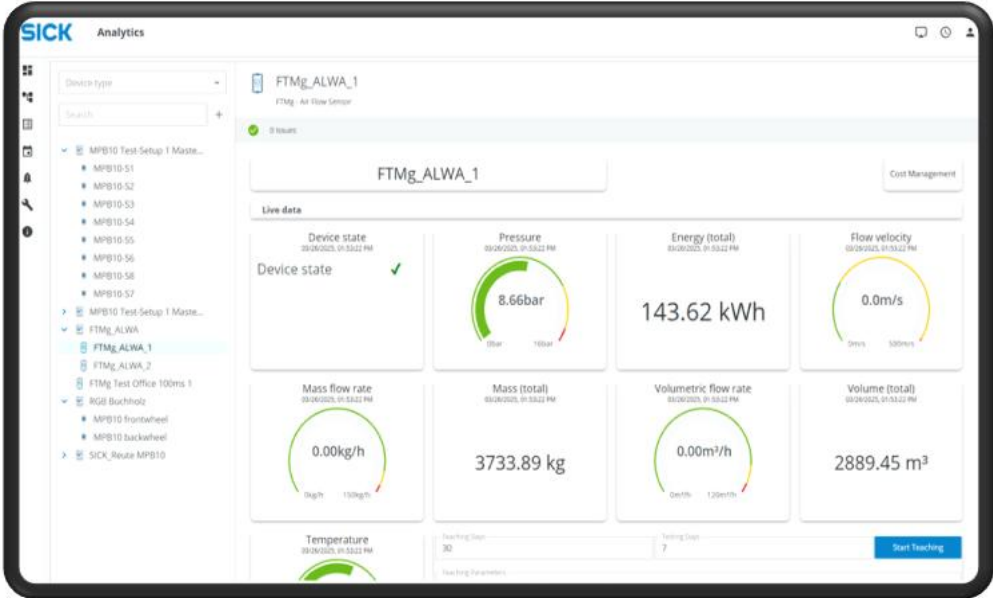
SENSORS



GATEWAYS

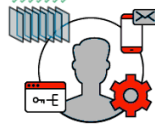


IIOT PLATFORM



IIOT PLATFORM - CYBERSECURITY

(1) Identity and Access management



(2) Data Protection & Encryption



(3) Application and API Protection



(4) Network and Environment security



(5) Security monitoring & Incident Response



(6) Secure Dev & Vulnerability management



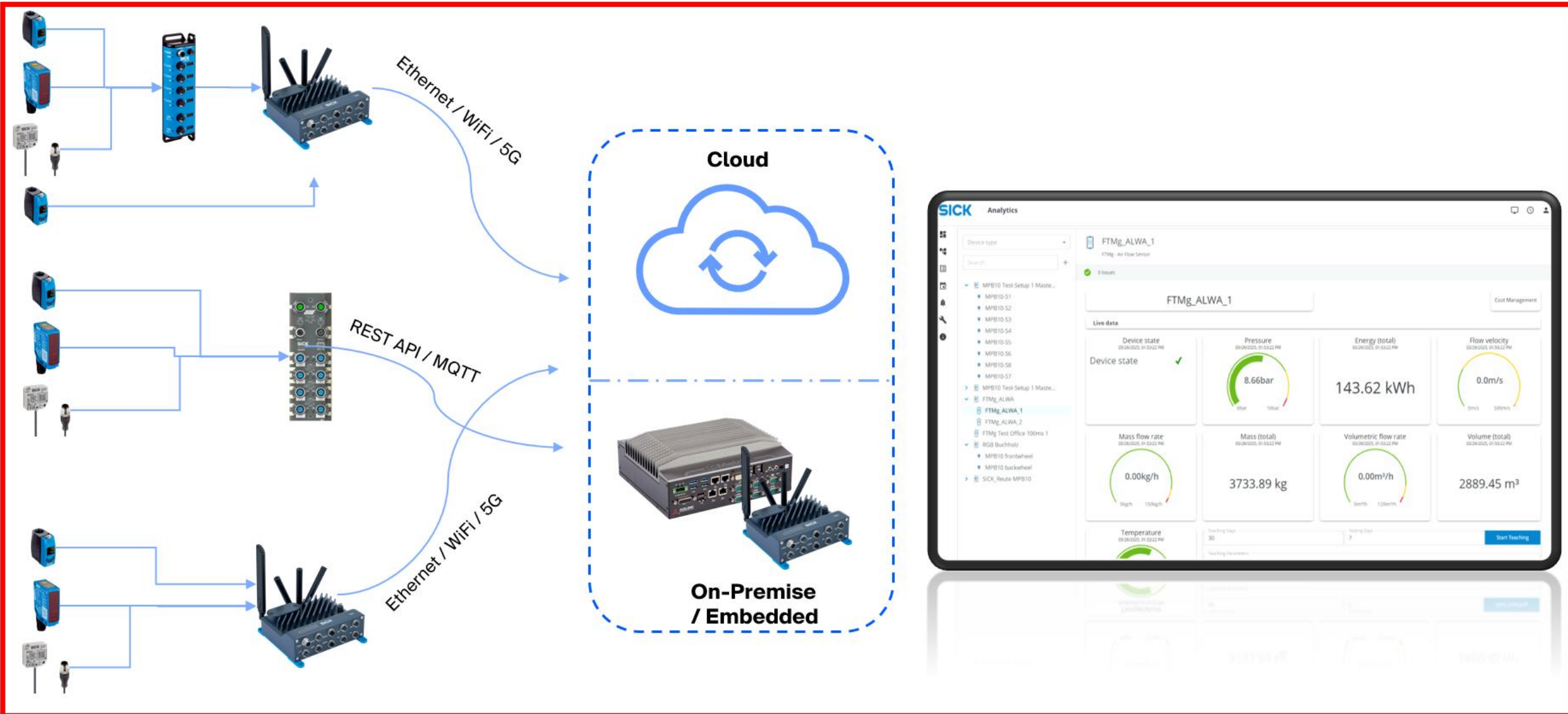
(7) Business continuity and recovery



(8) Compliance and governance



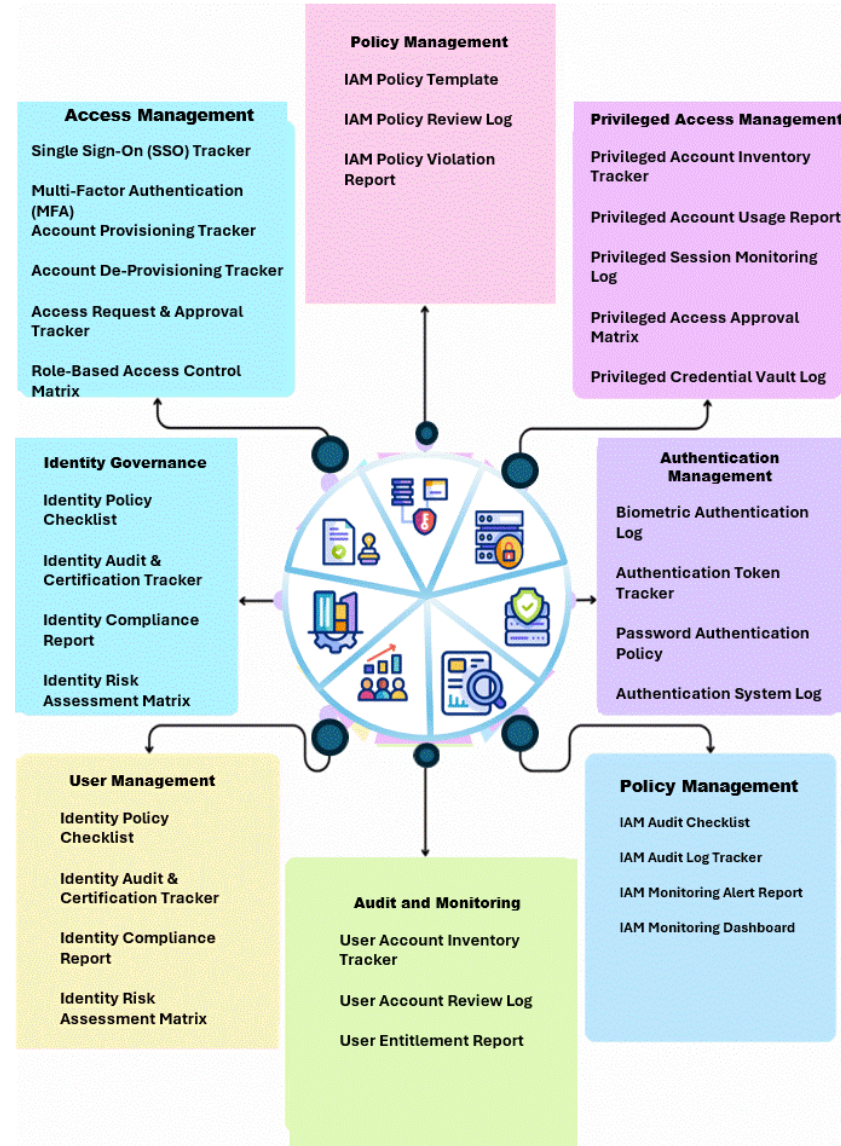
CYBERSECURITY BY DESIGN



(1) IDENTITY AND ACCESS MANAGEMENT

IAM elements

- 1. Identity Management
- 2. Authentication
- 3. Access Management
- 4. Monitoring



IDENTITY MANAGEMENT

Managing identities and their lifecycle across the system

Core Components

Area	Key Points
Identity Types	Users, Services, Devices
Lifecycle	Onboarding → Changes → Offboarding
Governance	Unique identities, no shared accounts, clear ownership

Objective

Full visibility and control over all identities in the system

AUTHENTICATION

Verifying identities before granting access

Core Methods

Method	Purpose
SSO	Centralized login
OAuth2/OIDC	Secure authentication flow
JWT	Token-based access
MFA	Additional security layer

Objective

Ensure only verified identities can access the system

Homework

ACCESS MANAGEMENT

Controlling who can access what

🔍 Core Principles

Principle	Focus
Least Privilege	Minimal access
Separation of Duties	Split responsibilities
Need-to-Know	Data-level restriction
Tenant Isolation	Customer separation

🎯 Objective

Ensure every access is controlled and justified

RBAC – Access based on roles

- Access model, usual

Privileged Access Management - **PAM**

Area	Control
Admin Access	Separate roles
Privileged Actions	Audit & monitoring
JIT Access	Time-limited privileges

Authenticated ≠ Authorized

IAM MONITORING

Visibility and control over identity-related activities



Monitoring Scope

Area	Focus
Authentication	Login & MFA events
Access	API & data access
Privileged Actions	Admin activities
Token Usage	JWT / token validation



Objective

Ensure visibility, detect threats, and enable traceability

- **Detection & Response** → identify and react to threats
- **Audit & Traceability** → ensure visibility and accountability

(2) DATA PROTECTION & ENCRYPTION

Protecting sensitive data across the platform

 Protection Scope

Area	Focus
Data Handling & Classification	Sensitive data handling, minimization, controlled exposure
Encryption	TLS (in transit) & encryption at rest
Key & Secret Management	Secure storage of keys, secrets & certificates

 Objective

Ensure confidentiality, integrity, and controlled access to sensitive data

ENCRYPTION – TLS IN PRACTICE

Understanding how data is protected

TLS protects communication between systems (`https://` → TLS is used)

Provides:

- **Confidentiality** (encryption)
- **Integrity** (protection against tampering)
- **Authentication** (server identity)

 **Used in:**

- Browser ↔ Application
- API calls
- Service-to-service communication

Questions/Homework:

1. What happens if TLS is not used?
2. Why is TLS critical for APIs?
3. What are key improvements in TLS 1.3 vs 1.2?

Homework

HTTP <> HTTPS

Understanding how data is protected

HTTPS = HTTP + TLS

HTTP	HTTPS
Plain text communication	Encrypted communication
No security	Secured with TLS
Data can be intercepted	Data is protected
Port 80	Port 443

→ **HTTP** is like a **postcard** — anyone can read it

→ **HTTPS** is like a **sealed envelope** — protected by TLS encryption

(3) APPLICATION AND API PROTECTION

API gateway

Centralized Access & Control

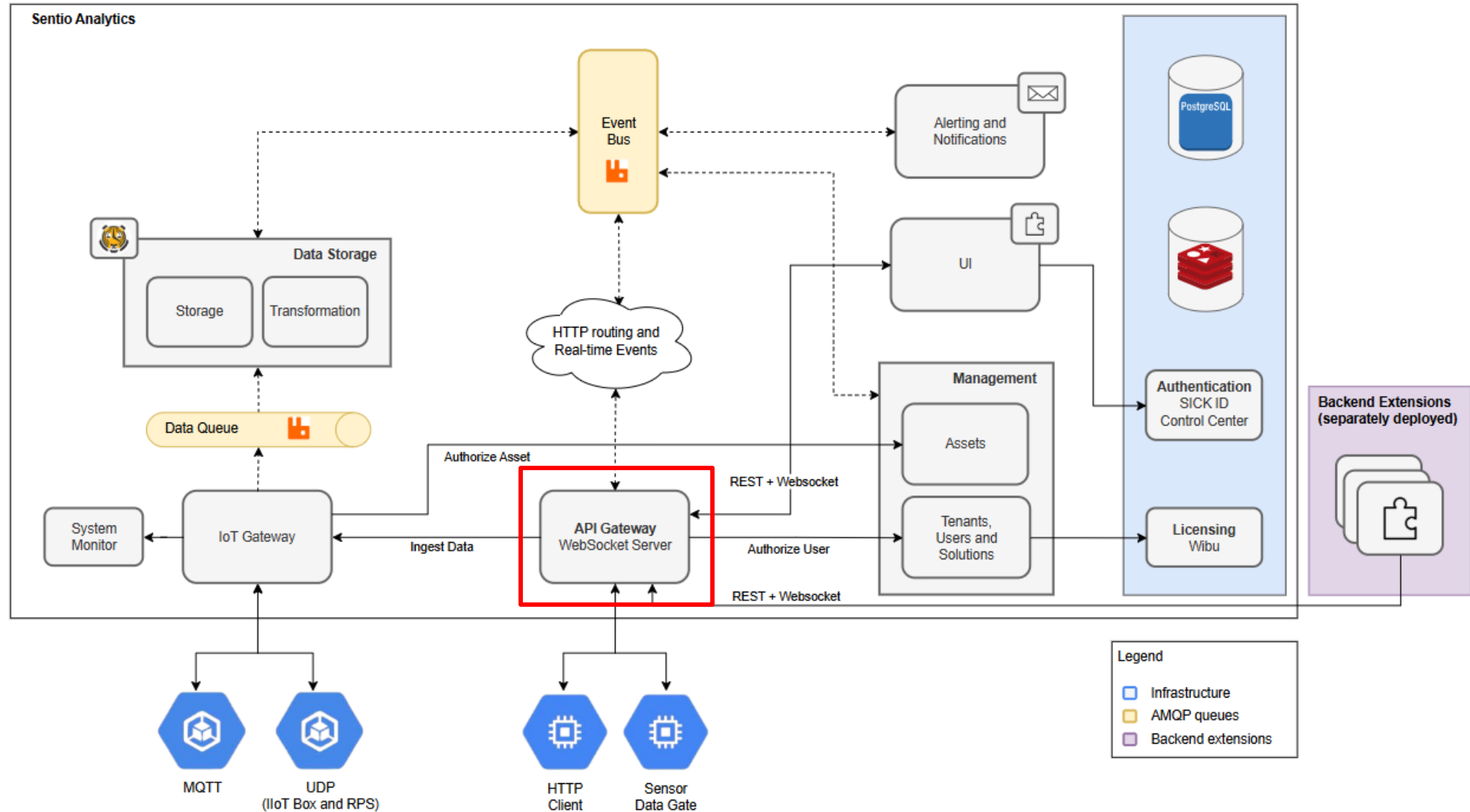
- **Centralized** API Gateway as single entry point
- Authentication and authorization **enforcement**
- Traffic **management** and request validation
- Consistent **security** policies across applications
- **Visibility** into API usage and behavior

Availability & Abuse Prevention

- **Rate limiting** to prevent API abuse and brute-force attacks
- **Throttling** to protect backend services
- **Prevention** of DoS and resource exhaustion
- **Early detection** of anomalous traffic patterns



ARCHITECTURE EXAMPLE



(3) APPLICATION AND API PROTECTION

Penetration Testing & OWASP Alignment

Penetration Testing (Pentest)

- Regular **internal & external** penetration testing
- Simulate **real-world attacks** to find exploitable weaknesses
- Combine **automated + manual** testing approaches
- **Validate effectiveness** of existing security controls
- Continuous **retesting & improvement** after remediation

OWASP Alignment

- Global organization defining **application security best practices**
- Provides **OWASP Top 10** – most critical web & API vulnerabilities
- **Industry standard** used in penetration testing and security assessments
- Focus on **real-world risks** (auth flaws, access control, injection, data exposure)
- Supports **continuous improvement** as applications and APIs evolve



(4) NETWORK AND ENVIRONMENT SECURITY

Dev, QA, UAT and PROD Segregation

Different environments are separated to:

- reduce risk
- improve control
- protect production systems from unintended changes or security incidents

Environment	Purpose	Risk Level	Key Security Principle
Dev	Development and initial integration	Higher	Isolated from production
QA	Functional and technical validation	Medium	Controlled testing access
UAT	Business/user acceptance testing	Medium	Representative but restricted
PROD	Live business operations	Critical	Strictest access and change control

Each environment has a distinct role, separate access model and stricter controls as systems move closer to production.

(4) NETWORK AND ENVIRONMENT SECURITY

Application Gateway and Web Application Firewall (WAF)

Web applications become more frequent targets for malicious attacks

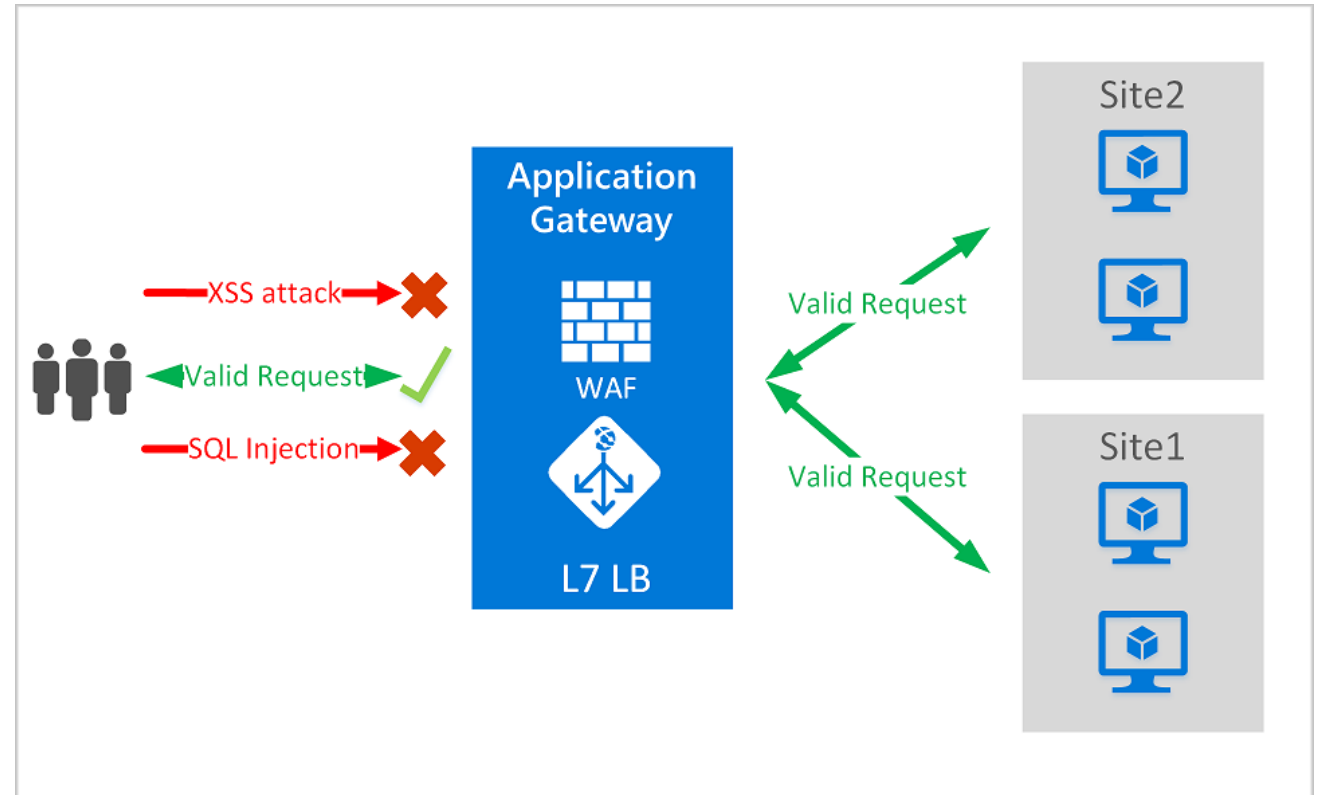
- these attacks often exploit well-known vulnerabilities such as SQL injection and cross-site scripting

Application Gateway

- TLS/SSL termination (decrypts traffic)
- Load balancing (round-robin)
- Content-based routing (smart traffic direction)
- Multi-site hosting
- Built-in security features

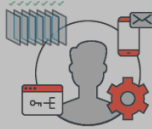
WAF

- Protects web apps from common attacks (SQL injection, XSS)
- Based on OWASP Core Rule Set (CRS)
- Filters and inspects HTTP/HTTPS traffic
- Configurable via WAF policies



IIOT PLATFORM - CYBERSECURITY

(1) Identity and Access management



(2) Data Protection & Encryption



(3) Application and API Protection



(4) Network and Environment security



(5) Security monitoring & Incident Response



(6) Secure Dev & Vulnerability management



(7) Business continuity and recovery



(8) Compliance and governance



(5) SECURITY MONITORING & INCIDENT RESPONSE

Centralized monitoring via SOC

24/7 centralized security monitoring (SOC)

→ continuous monitoring of all systems and timely threat detection

Advanced threat detection (SIEM, EDR)

→ automated detection of suspicious activities

→ log and behavior analysis

Fast and structured incident response

→ clearly defined processes for rapid response

→ damage containment, and system recovery



(5) SECURITY MONITORING & INCIDENT RESPONSE

Centralized monitoring via SOC

What is a **SOC acronym**?

What is an **EDR acronym**?

What is a **SIEM acronym** and what is its role?

Understanding the flow

- How does an **EDR agent detect a threat** on an endpoint?
- What kind of data/logs are sent to the **SOC**?
- What happens after an **alert is triggered**?

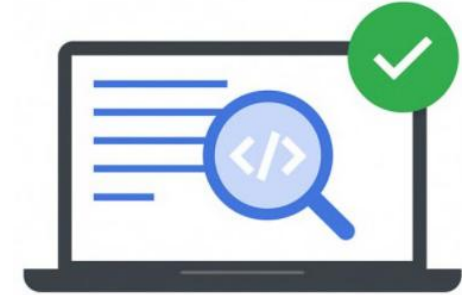
Deeper thinking / homework

- What is the difference between **EDR and traditional antivirus**?
- What does a typical **incident response process** look like (steps)?

(6) SECURE DEV & VULNERABILITY MANAGEMENT

(1) SAST tools

- **Analyze** source code to identify security issues
- **Detect** vulnerabilities early in the development lifecycle
- **Integrated** into CI/CD pipelines
- **Help** developers fix issues before deployment



(2) Vulnerability scanning

- **Scan** systems and applications for known vulnerabilities
- **Detect** CVEs, misconfigurations, and outdated components
- **Support** regular and continuous scanning
- **Enable** risk-based prioritization and remediation



(6) SECURE DEV & VULNERABILITY MANAGEMENT

3) SBOM – Software Bill of Materials

- **Inventory** of software components and dependencies
- **Improves** visibility into third-party and open-source risk
- **Supports** compliance and supply chain security



4) PSIRT – Product Security and Incident Response Team

- **Manages** product security vulnerabilities and incidents
- **Coordinates** analysis, remediation, and disclosure
- **Acts** as a central point for security advisories and communication
- **Ensures** timely response to reported vulnerabilities



(7) BUSINESS CONTINUITY AND RECOVERY

Backups

- **Regular** and automated backups of critical systems and data
- **Secure** storage and integrity validation of backup data
- **Defined** backup frequency aligned with business criticality

Recovery Procedures

- **Clearly** documented and tested recovery procedures
- **Regular** disaster recovery and restore **testing**
- **Roles and responsibilities** defined for recovery activities

Recovery Objectives

- Defined **RTO** and **RPO** aligned with business requirements
- Recovery priorities based on system and data criticality
- Continuous review to reflect business and technology changes

3-2-1 Backup Rule

3 copies of data

- 1 primary copy
- 2 backup copies

2 different storage types

- For example: disk + cloud, or
- NAS + tape (reduces the risk of media failure)

1 copy off-site

- Stored in a **separate location**
- protects against ransomware and disasters

(8) COMPLIANCE AND GOVERNANCE

Security by Design

- Security **embedded** from the earliest design phase
- **Risk-based** approach across applications, APIs, and infrastructure
- **Secure** defaults and least-privilege principles
- **Consistent policies** across IT, OT, IoT, and cloud environments
- Security treated as a **continuous lifecycle**, not a one-time task

Security is not a control — it's an engineering practice.

Homework

What is DevSecOps ?

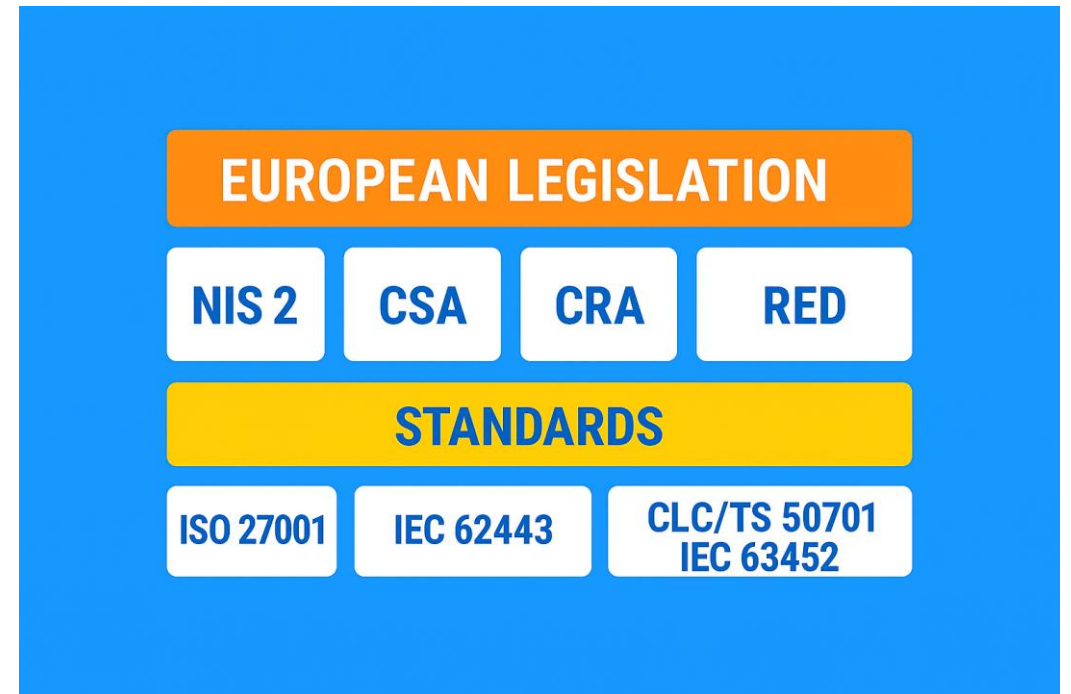
EUROPEAN LEGISLATION

EU Legislation

- **NIS2** – Organizational cyber governance
- **CRA** – Secure digital products
- **CSA** – Cybersecurity certification
- **RED** – Secure radio & IoT devices

Standards

- **ISO 27001** – Information security management
- **IEC 62443** – OT / ICS security
- **CLC/TS 50701** – Rail cybersecurity
- **IEC 63452** – Rail communication security



(8) COMPLIANCE AND GOVERNANCE

NIS2 vs. Cyber Resilience Act (CRA)

NIS2 (Operational & Organizational Focus)

- **Governance**, risk management, and incident handling
- **Defined** roles, responsibilities, and accountability
- Security **controls** across IT, OT, cloud, and operations
- **Auditability** through policies, processes, and reporting
- Focus on **organizational** resilience and compliance

Cyber Resilience Act (Product & Lifecycle Focus)

- **Security-by-design** for digital products and software
- **Secure development** and vulnerability management lifecycle
- **Continuous** patching and vulnerability disclosure
- **Evidence** of security controls built into products
- Focus on **product trust** and market readiness

NIS2 secures **organizations**; **CRA** secures **products** — together they enforce **end-to-end cyber resilience**

Cybersecurity awareness



- Basic cybersecurity hygiene
- Best practices („Golden rules“)
- NIS2 measure/topic

„Cybersecurity Friday“

- Newsletter campaign
- Starts on **Friday, September 5th**
- Detailed **explanation** of each rule
- Interesting and engaging content

ZLATNA PRAVILA KIBERNETIČKE ZAŠTITE

1. RUKOVANJE LOZINKAMA

Koristi jake i jedinstvene lozinke koje sadrže velika i mala slova, brojeve i simbole. **Nikada ih ne zapisuj na papir niti dijeli s drugima.** Za sigurnu pohranu koristi password manager poput KeePass-a.



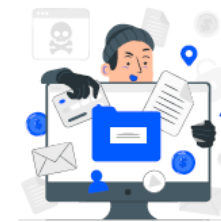
2. OČISTI STOL, ZAKLJUČAJ EKRAN

Kad odlaziš od računala, **uvijek zaključaj ekran** pomoću Win + L. Povjerljive dokumente spremi pod ključ, a one koji ti više ne trebaju sigurno uništi – **ne ostavljaj ih u običnom smeću.**



3. KLIKAJ PAMETNO, PIŠI SIGURNO

Ne otvaraj sumnjive e-maileve, privitke i linkove, čak i ako izgledaju legitimno. Prije nego što klikneš, **provjeri stvarnog pošiljatelja** i svrhu poruke. Povjerljive podatke nikada ne šalji nezaštićene putem e-maila.



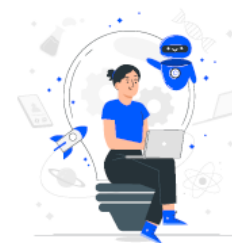
4. POVEŽI SE SIGURNO, PRISTUPI PAMETNO

Za posao koristi **isključivo poslovno računalo** i poveži se putem Check Point VPN klijenta. **Privatni uređaji nisu dopušteni** za pristup poslovnim sustavima jer nisu pod sigurnosnim nadzorom.



5. PAMETNO S AI-JEM

AI alati mogu biti korisni, ali u njih nikada **ne unosi povjerljive** ili osjetljive podatke. Poštuj pravila zaštite podataka i klasifikacije informacija kako bi se osigurala **sigurna primjena umjetne inteligencije.**



6. ANTIVIRUS JE VEĆ AKTIVAN

Sva poslovna računala imaju aktivnu antivirusnu zaštitu koja stalno nadzire prijetnje. **Ne instaliraj dodatne programe** niti mijenjaj sigurnosne postavke.





THANK YOU.